

A certified cyber range for automated defenders: provable residual-risk guarantees against an adaptive adversary

2026-09-21 (work-in-progress, version 0.2.0)

Abstract

Autonomous cyber-defense systems are judged almost entirely by *empirical* outcomes—attack-success rate, flags captured—which say nothing provable about the residual risk a defender leaves behind, least of all against an adversary that adapts. We describe a small *cyber range* that scores automated defenders with a *provable* verdict instead. Built on the real MITRE ATT&CK Enterprise kill chain (v17.1, 44 mitigations) and an evidence-anchored hospital-ransomware impact model, the range returns, for any control portfolio, a distribution-free *guaranteed/possible* adequacy certificate: the worst-case probability that at least k clinical services suffer simultaneous sustained outage stays below ε , over all failure-dependence structures and all parameters in an interval uncertainty set. It scores each defender against *two* adversaries—a *typical* one (usage-weighted technique mix) and an *adaptive* one that best-responds by routing through the easiest uncovered technique each stage. The provable score exposes something an empirical one cannot: against the adaptive adversary, 10 of the 12 adaptive regimes (assumed degradation) cannot be certified by *any* portfolio, because some ATT&CK techniques carry no mitigation and the worst-case attacker always routes through them. (The two adversaries coincide before any control is deployed—with no mitigations every technique’s residual equals the base rate, so mean and maximum agree at 44.9%—and diverge only as controls are added and the adaptive attacker re-routes around them.) Where certification is possible, using the certificate as feedback cuts a certificate-blind heuristic’s control burden by about a third under the typical adversary, but a greedy defender tuned to reachability can still fall far short of the exact optimum against the adaptive one. The defender API is agent-agnostic, so an agentic/LLM defender drops in unchanged—the intended next step. This is an evaluation-environment contribution, not a new theorem or a validated real defense.

1 The range

A defender chooses a *control portfolio*: a set of ATT&CK mitigations (M####). Via the real **mitigates** edges, each mitigation lowers the success probability of the techniques it covers, and the kill-chain reachability to the ransomware impact objective composes those into a per-clinical-service sustained- outage probability. The range’s **score** is the certificate, not a sampled outcome: worst- and best-corner evaluation over the interval uncertainty set gives a *guaranteed* verdict (adequate even at the adverse corner) and a *possible* one; the catastrophic k -of- n event uses a sharp closed-form aggregation bound (a minimum over dependence structures), so the verdict holds whatever the true correlation between service failures. The observation (named mitigations, techniques covered, stages touched), the action (add/remove a mitigation), and the certified score form an agent-agnostic API.

2 Two adversaries

The certificate’s default reachability is a *typical* adversary: each kill-chain stage succeeds with the usage-weighted mean residual over its techniques. We add an *adaptive* adversary that best-responds to the current defense—stage success is the *maximum* residual over the stage’s techniques, i.e. the attacker routes through whatever the defender left most open. This is the closed-form best response (no iteration): as the defender covers the easiest path, the adversary’s maximum shifts to the next. Adaptive reachability dominates the typical one pointwise, so the adaptive certificate is a strictly stronger guarantee, and it stays monotone, so the interval-corner certificate is still exact. Scoring defenders against it makes the range genuinely *dynamic*.

3 Reference defenders and regimes

We score four automated (non-LLM) defenders: an *exact* minimum-cost optimiser (budget-bounded search, feasible because adequacy is monotone in the portfolio); a *greedy* defender adding the mitigation with the largest worst-case reachability reduction (certificate-guided); a *coverage* heuristic maximising techniques covered while ignoring the certificate; and a seeded *random* policy. Each is scored across 48 regimes: both adversaries $\times$ assumed vs. real CIPHER-derived degradation $\times$ adequacy levels $\varepsilon \in \{0.10, 0.05, 0.01\} \times$ catastrophic thresholds $k = 1..4$. The metric is *cost-to-certify*: the smallest portfolio a defender reaches that the range certifies as adequate, or “none” when no portfolio does.

4 Results

Under the typical adversary, using the certificate as feedback cuts the control burden by about a third: the greedy defender averages 2.6 controls against 4.1 for the certificate-blind coverage heuristic, close to the exact optimum’s 1.6 (Table 1). The adaptive adversary changes the picture sharply. It is undefendable in most regimes: 10 of the 12 adaptive regimes (assumed degradation) admit *no* certifying portfolio at any cost (Table 2), because some techniques carry no ATT&CK mitigation and the worst-case attacker always routes through them. Where certification *is* possible ($\varepsilon = 0.10$, $k = 3$), the certificate-guided greedy defender needs 26 controls against the adaptive adversary while the exact optimum needs 4—so a defender tuned to the reachability objective can be far from the catastrophic optimum, and only a provable score reveals either the gap or, more importantly, that no portfolio suffices. Indeed, averaged over the adaptive regimes it can certify, greedy (17.3 controls) costs *more* than the certificate-blind coverage heuristic (15.3; Table 1): a reachability-tuned ordering can actively mislead against an adaptive adversary. An empirical attack-success benchmark would report a low sampled failure rate for the same portfolios and hide all of this.

5 Why the adaptive adversary is undefendable: the reachability floor

The uncertifiability is not a quirk of the numbers; it has a mechanism the range makes explicit. Adaptive reachability is monotone in the portfolio, so deploying *every* mitigation attains the global minimum — the *reachability floor*. A kill-chain stage that contains a technique MITRE lists *no* mitigation for keeps that technique’s residual at the base rate no matter what is deployed, so the

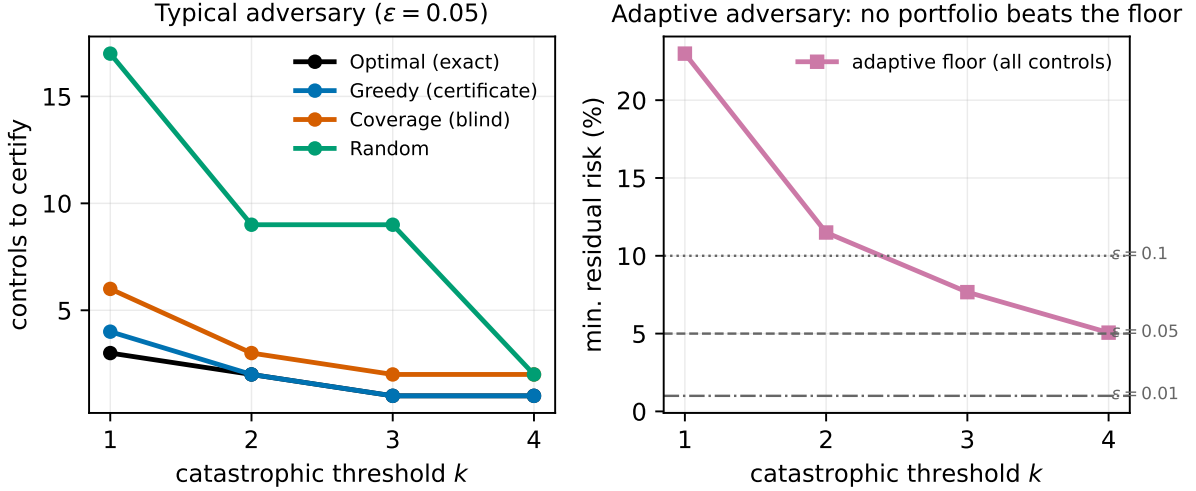


Figure 1: Left: under the typical adversary, cost-to-certify falls with k and the certificate-guided greedy defender tracks the exact optimum while the blind heuristics lag. Right: under the adaptive adversary, the reachability floor (all controls deployed) sits above ε for small k , so no portfolio certifies there.

Table 1: Reference defenders by mean cost-to-certify (over the regimes they could certify), under the typical and the adaptive adversary, with the fraction of all 48 regimes certified.

Defender	Certified (%)	Mean (typical)	Mean (adaptive)
Optimal (exact)	50	1.6	2.0
Greedy (certificate)	62	2.6	17.3
Coverage (blind)	62	4.1	15.3
Random	62	10.4	20.3

floor cannot fall below it. In ATT&CK v17.1, 10 of 12 stages contain such a technique (worst: defense-evasion, with 36 of 211 techniques uncovered; Table 3), which floors the fully-defended adaptive reachability at 14.5% and the catastrophic bound at 23.0% for $k=1$, falling to 5.1% at $k=4$ (Figure 1, right). Certification under the adaptive adversary is therefore possible only where the floor drops below ε — which is why only the largest- k , loosest- ε regimes certify. This is a structural gap, not a pessimistic prior: even the most optimistic effectiveness prior leaves 7 of 12 adaptive regimes uncertifiable, because no effectiveness value can cover a technique that has no mitigation at all.

6 Scope and limitations

To our knowledge this is the first to score automated defenders with a *distribution-free*, *provable* residual-risk certificate rather than an empirical outcome; ATT&CK-based defender-policy evaluation and optimisation-based control selection that minimises residual risk are established lines of work, and what is ownable here is the provable score and the adaptive-adversary reachability floor it exposes, not the idea of scoring defenders on ATT&CK. It is realistically a work-in-progress contribution—not a new theorem (the certificate and the closed-form k -of- n bound are prior work)

Table 2: Cost-to-certify per regime under the *adaptive* adversary (assumed degradation). “none” means no portfolio certifies at any cost; “>4” means the exact optimum exceeds the search cap.

ε	k	Optimal	Greedy	Coverage	Random
0.10	1	none	none	none	none
0.10	2	none	none	none	none
0.10	3	4	26	26	33
0.10	4	0	0	0	0
0.05	1	none	none	none	none
0.05	2	none	none	none	none
0.05	3	none	none	none	none
0.05	4	none	none	none	none
0.01	1	none	none	none	none
0.01	2	none	none	none	none
0.01	3	none	none	none	none
0.01	4	none	none	none	none

and not a validated real-world defense. Most pointedly for an agentic-defense venue, the defenders evaluated here are classical search procedures, not autonomous agents: the contribution is the evaluation environment and the guarantee it enforces, and the agent-agnostic API is the intended bridge, but no agentic defender is evaluated in this draft. MITRE ATT&CK and the CIPHER harm corpus are real; the hospital is synthetic, since real hospital maps and per-incident telemetry are not public. Effectiveness and degradation are analyst-prior intervals anchored to published figures, never incident measurements, and the certificate verdicts are conditional worst-case frequencies under those intervals, not statistical confidence levels. The adaptive adversary is a worst-case routing model, not a learned attacker; that it renders many regimes undefendable is a statement about ATT&CK mitigation *coverage* under a worst-case assumption, not a claim that real defense is hopeless. The reference defenders are deliberately simple automated policies. The value of the range is that its score is a *provable* residual-risk bound—holding even against an adversary that adapts, and able to say “no portfolio suffices”—rather than an average, and that an agentic defender can be dropped into the same API and held to the same guarantee.

Reproducibility. All numbers are generated from committed tables; the benchmark is deterministic (a single fixed seed for the random policy) and carries a provenance manifest recording the SHA-256 of every input and output over the pinned ATT&CK bundle and the CIPHER corpus. No LLM or network access is used.

Table 3: ATT&CK coverage gaps per kill-chain stage: techniques modelled and how many carry no mitigation (the uncoverable frontier that sets the reachability floor).

Stage	Techniques	No mitigation
initial-access	22	0
execution	43	1
persistence	125	14
privilege-escalation	108	14
defense-evasion	211	36
credential-access	67	4
discovery	47	33
lateral-movement	23	1
collection	40	13
command-and-control	45	3
exfiltration	19	1
impact	4	0